

Building a Compliant Security Profile: ND TZI and NIST Certification for ERPUNO, COURT and COD security profiles

ERPUNO Security Team

14 червня 2026 р.

Abstract

This article details the methodology for constructing a Comprehensive Information Security System (KSZI) that complies with Ukrainian state standards (ND TZI) and the international NIST SP 800-53 framework. Using SYNRC/CA — an open source CMDB we demonstrate how to programmatically define, track, and audit a security profile. The approach utilizes Elixir-based Configuration Management Database (CMDB) profiles to maintain strict accountability over hardware, software, networks, data, roles, and risks. For security reasons we can only demo/showcase of ERPUNO security (sample) profile.

Contents

1	Introduction	5
2	Beyond KSZI: A Continuous Accountability System (CMDB)	6
2.1	Detailed NIST SP 800-53 Rev.5 Control Integrations	6
2.1.1	CM-8: System Component Inventory	6
2.1.2	CM-8(1) & CM-8(2): Inventory Updates & Tracking . . .	6
2.1.3	CM-9: Configuration Management Plan	6
2.1.4	PM-5 & PM-6: System Inventory & Measures of Performance	7
2.1.5	CA-7: Continuous Monitoring	7
2.1.6	PL-2, RA-2, RA-3: Security Plans & Risk Assessments . .	7
2.1.7	AC-2, AC-3 & AC-25: Access Control Enforcement & Reference Monitor	7
2.1.8	SC-8 & SC-28: Transmission Confidentiality & Data at Rest	8
2.1.9	SC-12: Cryptographic Key Establishment and Management .	8
2.1.10	AU-2 & AU-6: Audit Events & Analysis	8
2.1.11	IA-2: Identification and Authentication	8
2.1.12	SA-5 & PL-2: Automated System Documentation & Security Plans	8
2.1.13	CP-9 & CP-10: Information System Backup & Recovery .	9
2.2	Detailed ND TZI (State Standard) & ISO Compliance	9
2.2.1	ND TZI 3.7-003-2023 §4.2 & §5: Exploitation Documentation	9
2.2.2	ND TZI 1.6-005-22 & 2.6-001-11: State Expertise Audit Trails	9
2.2.3	ND TZI 2.5-004-99 & 2.5-005-99: System Classification & Evaluation	10
2.2.4	ND TZI 3.6-006-24: Critical State Registries	10
2.2.5	ND TZI 2.5-008-02: Confidential Information Protection .	10
2.2.6	ND TZI 2.5-010-03: Web Application Protection	10
2.2.7	ISO/IEC 27001:2022 & DSTU ISO/IEC 27001:2015: ISMS Alignment	10
3	Hierarchical Security Profiles (L1, L2, L3)	12
3.1	L1: Basic Security Profiles	12
3.2	L2: Industry Profiles	12
3.3	L3: Target Security Profiles	12
4	Segregation of Duties: The Two-Stage KSZI Certification Process	13

5	Programmatic Security Profiles	14
5.1	Risk Assessment (CA.PRO.risk)	14
5.2	System Software Components (CA.PRO.sys)	15
5.3	Hardware Inventory (CA.PRO.inventory)	15
5.4	Role-Based Access Control (CA.PRO.roles)	16
5.5	Data Categorization (CA.PRO.data)	16
5.6	Business Processes (CA.PRO.proc)	16
5.7	Network Architecture (CA.PRO.net)	17
6	ERP/1: Відповідність повному стеку контролів NIST SP 800-53	18
6.1	Клас AC: Управління доступом	18
6.1.1	zencrypted/ias: AC-2 — Управління обліковими записами	18
6.1.2	zencrypted/ias: AC-7 — Невдалі спроби входу	19
6.1.3	synrc/ca: AC-3 — Забезпечення доступу	20
6.1.4	synrc/bpmn: AC-4 — Управління інформаційними потоками	21
6.1.5	erpuno/abac: AC-5 та AC-6 — Розмежування та мінімізація повноважень	21
6.2	Клас AT: Навчання та обізнаність	22
6.2.1	synrc/ca: AT-2, AT-3 — Навчання з питань безпеки	22
6.3	Клас AU: Аудит та підзвітність	22
6.3.1	zencrypted/ias: AU-2, AU-3, AU-6, AU-12	22
6.4	Клас CA: Оцінка, авторизація та моніторинг	23
6.4.1	synrc/ca: CA-2, CA-6, CA-7, CA-8, CA-9	23
6.5	Клас CM: Конфігураційне управління	24
6.5.1	synrc/ca CMDB: CM-2, CM-3, CM-6, CM-7, CM-8, CM-9	24
6.6	Клас CP: Планування безперервності	24
6.6.1	erlang/otp: CP-2, CP-7, CP-9, CP-10	24
6.7	Клас IA: Ідентифікація та автентифікація	25
6.7.1	synrc/ca + zencrypted/ias: IA-2, IA-5, IA-8	25
6.8	Клас IR: Реагування на інциденти	25
6.8.1	erpuno/itsm: IR-1, IR-4, IR-5, IR-6, IR-8	25
6.9	Клас MA: Технічне обслуговування	26
6.9.1	erpuno/itsm: MA-2, MA-4, MA-5	26
6.10	Клас MP: Захист носіїв інформації	26
6.10.1	synrc/kvs: MP-2, MP-4, MP-5, MP-6, MP-7	26
6.11	Клас SC: Захист систем та комунікацій	27
6.11.1	synrc/vpn: SC-7, SC-8, SC-10, SC-12, SC-28	27
6.12	Клас SI: Цілісність системи та інформації	27
6.12.1	synrc/chat: SI-3, SI-4, SI-7, SI-10	27
6.13	Клас SR: Ризики ланцюга постачання	28
6.13.1	synrc/chat + synrc/ca: SR-3, SR-4, SR-5, SR-11	28
6.14	Блоки PL, PS, RA, SA, PM, PT	28
6.14.1	synrc/ca CMDB: PL-2, RA-2, RA-3, SA-5	28

7	Codebase Overview for Copyright Registration	30
8	Conclusion	31

1 Introduction

ERPUNO LLC provides high-tech telecommunication solutions for the automation of commercial and state enterprises. Their platform is architecturally divided into two primary layers:

- **Platform (SYS-APP-SYNRC):** The systemic foundation, including the Certificate Authority (CA), L2/L3 VPN tunnels, PKI-aware LDAP, Communicator (CHAT), BPMN process engine, MQTT broker, and KVS storage.
- **Products (SYS-APP-ERP):** Corporate and state enterprise systems such as Education (Edu), Healthcare (Health), Electronic Documents (Mail), Accounting (Acc), Warehouse Management, and Registries (Cart).

The company's architecture is built to support critical state and defense sector needs. It offers special licensing conditions for government applications, provided there is strict adherence to architectural compatibility and certification requirements (like DSSZZI). The system strictly follows ITU-T X-series, IETF RFC, NIST/FIPS, DSTU, and ISO/IEC standards (e.g., X.509, CMS/S-MIME, AES-GCM, Kyber, DSTU 4145-2002).

In this paper, we demonstrate how to build a unified security profile for this complex architecture. The CMDB system maps operational instances directly to NIST SP 800-53 controls (such as CM-8 for System Component Inventory, PM-5 for System Inventory) and ND TZI requirements (e.g., ND TZI 3.7-003-2023 for inventory and exploitation documentation).

2 Beyond KSZI: A Continuous Accountability System (CMDB)

Traditional KSZI (Comprehensive Information Security Systems) are often treated as static, paper-based compliance artifacts. However, for ERPUNO LLC, we engineered the KSZI as a live, programmable **Configuration Management Database (CMDB)** and **Continuous Accountability System**.

This system is inherently built into the source code using Elixir modules (e.g., `hw.ex`, `sys.ex`, `net.ex`). The core Certificate Authority (`SYS-SYNRC-CA`) acts not only as the PKI infrastructure but also as the central registry for this accountability system. The profile of this system explicitly implements the following security controls:

2.1 Detailed NIST SP 800-53 Rev.5 Control Integrations

2.1.1 CM-8: System Component Inventory

The CMDB maintains a strict, programmatically queryable registry of all hardware, software, and firmware components across the entire infrastructure. This is not merely a static spreadsheet; it is an active Elixir dataset (`hw.ex`, `sys.ex`) that tracks inventory numbers, physical locations, operational status, and cryptographic module certifications. By natively linking every physical switch, server, and HSM to its exact operational context, the system completely eradicates drift between actual infrastructure and security documentation. The inventory control ensures full visibility and reduces the attack surface by identifying rogue or unauthorized devices instantaneously.

2.1.2 CM-8(1) & CM-8(2): Inventory Updates & Tracking

The architecture guarantees the automated maintenance and tracking of component updates during all installations, removals, or migrations. Because the CMDB is stored as Elixir source code within a secure Git repository, every single alteration to the infrastructure creates an immutable, cryptographically signed commit. This mechanism automatically fulfills the requirement for strict version control and historical auditing of hardware and software lifecycles. It provides an unbroken chain of custody for all system components, essential for forensic analysis and compliance verification.

2.1.3 CM-9: Configuration Management Plan

Rather than maintaining a separate textual document that inevitably becomes obsolete, the entire Configuration Management Plan is directly codified within the repository itself, treating policy strictly as code. The build, deployment, and auditing pipelines are governed by these exact declarative profiles. Any deviation in production from the CMDB profile immediately triggers a compliance alert, ensuring the configuration management plan is actively enforced at all

times. This shift from prescriptive documentation to declarative code enforces continuous compliance inherently.

2.1.4 PM-5 & PM-6: System Inventory & Measures of Performance

The `CA.PRO` API delivers real-time, system-wide inventory tracking and verifiable measures of performance to organizational stakeholders. Instead of relying on manual quarterly audits, security officers can execute programmatic queries against the CMDB to instantly extract precise metrics, asset valuations, and compliance coverage ratios, significantly reducing administrative overhead and human error. This control effectively shifts the compliance burden from human operators to automated, highly reliable programmatic interfaces.

2.1.5 CA-7: Continuous Monitoring

The security architecture integrates natively with SIEM/XDR solutions (such as Wazuh) to provide a constant, real-time status feed of all critical security controls and operational events. This continuous monitoring pipeline digests syslog, eBPF telemetry, and application logs, correlating them directly against the risk taxonomies and compliance profiles defined in the CMDB. This ensures that any degradation in security posture is immediately detected and addressed, shifting the paradigm from point-in-time assessment to perpetual situational awareness.

2.1.6 PL-2, RA-2, RA-3: Security Plans & Risk Assessments

The system implements automated system security plans, data categorization matrices, and risk taxonomies directly through the `CA.Data` and `CA.Risk` modules. Risks are not just listed; they are systematically mapped to the exact software vulnerabilities, network segments, and data stores they impact. This programmatic risk assessment allows for dynamic recalculation of the system's risk profile whenever new infrastructure is introduced. It provides a living threat model that continuously aligns security mitigations with actual business risks.

2.1.7 AC-2, AC-3 & AC-25: Access Control Enforcement & Reference Monitor

Role-based (RBAC) and Attribute-based (ABAC) access control mechanisms are centrally defined within the `roles.ex` hierarchy. These policies dictate precise permissions across all environments and are strictly enforced at the application boundary via a unified Reference Monitor (AC-25). This guarantees that all access decisions—whether for a standard user or a global administrator—are verified against the immutable policy engine before any action is permitted. Centralizing access control logically prevents bypasses and privilege escalation across disparate subsystems.

2.1.8 SC-8 & SC-28: Transmission Confidentiality & Data at Rest

Mandatory cryptographic controls are bound directly to the hardware and network profiles. For data in transit, the CMDB mandates IPsec/MACsec tunnels across all core switches and border gateways, explicitly defining the cryptographic suites. For data at rest, Transparent Data Encryption (TDE) and hardware-level SAN encryption are mandated for all storage arrays, ensuring that physical theft or unauthorized access to drives yields zero intelligible data. These controls provide an impenetrable cryptographic envelope protecting the state's most sensitive data assets.

2.1.9 SC-12: Cryptographic Key Establishment and Management

The SYS-SYNRC-CA core functions as the centralized Public Key Infrastructure (PKI), managing the entire lifecycle of all symmetric and asymmetric keys. Backed by certified Hardware Security Modules (HSMs, e.g., IIT Gryada-301), the system ensures secure key generation, escrow, rotation, and revocation. This provides an unassailable cryptographic foundation for the entire e-government platform. The rigorous key management protocol eliminates the risk of key compromise or weak cryptography being introduced ad-hoc by system administrators.

2.1.10 AU-2 & AU-6: Audit Events & Analysis

The platform defines its auditable events explicitly within the CMDB outputs, ensuring that all security-relevant activities (logons, privilege escalations, key accesses) are definitively logged. Automated mechanisms and SIEM integrations are deployed to continuously analyze these audit records for anomalous behavior, satisfying the requirement for proactive threat detection and non-repudiation of user actions. This closed-loop auditing ensures that incidents are not merely logged, but actively responded to in near real-time.

2.1.11 IA-2: Identification and Authentication

Organizational users, administrators, and automated service accounts are uniquely identified and authenticated using strict multi-factor authentication (MFA) protocols, including PKI smart cards and OTP tokens. These identities are irrevocably tied to the `roles.ex` taxonomy, preventing identity spoofing and ensuring that every session is cryptographically bound to an authorized entity. The rigorous identity management protocol establishes a zero-trust foundation where no user is trusted inherently without verifiable cryptographic proof.

2.1.12 SA-5 & PL-2: Automated System Documentation & Security Plans

The most innovative aspect of the CMDB architecture is the fulfillment of SA-5 (System Documentation) and PL-2 (System Security Plan). Instead of

maintaining static text documents, the entirety of the KSZI documentation—including the overarching security plans, asset registries, risk matrices, and this very PDF report—is automatically generated directly from the live Elixir source code. By compiling the current system state into documentation on demand via a "Documentation as Code" (DaC) paradigm, the organization completely eliminates the phenomenon of "documentation drift." This guarantees that auditors and state regulators always evaluate a 100% accurate reflection of the deployed system, significantly reducing the cost and friction of DSSZZI and NIST compliance audits.

2.1.13 CP-9 & CP-10: Information System Backup & Recovery

The categorization of data assets within the CMDB directly governs the automated backup schedules. Critical databases and file stores are subjected to continuous replication, while sensitive offline archives are routed to air-gapped tape libraries (e.g., HPE StoreEver). This guarantees robust disaster recovery capabilities and strict protection against ransomware or catastrophic hardware failures. The recovery protocols ensure minimal recovery point objectives (RPO) and recovery time objectives (RTO), crucial for high-availability enterprise services.

2.2 Detailed ND TZI (State Standard) & ISO Compliance

2.2.1 ND TZI 3.7-003-2023 §4.2 & §5: Exploitation Documentation

According to Ukrainian state standards, the accountability of protected objects and the generation of exploitation documentation are critical for state expertise. This system automatically generates all required technical passports, inventory logs, and component registries directly from the `inventory_num` and `serial` fields within the CMDB. This completely eliminates manual paperwork and ensures absolute accuracy during DSSZZI audits. This automation accelerates the certification process and removes the human error typically associated with maintaining extensive paper-based documentation.

2.2.2 ND TZI 1.6-005-22 & 2.6-001-11: State Expertise Audit Trails

Security requirements and audit trails required for the State Expertise of the KSZI are dynamically extracted from the `controls` field embedded within each profile. The system can instantly produce a complete mapping of implemented controls against the regulatory requirements, providing auditors with transparent, code-backed evidence of compliance rather than unverifiable assertions. This verifiable link between state regulation and physical implementation provides unparalleled assurance during regulatory inspections.

2.2.3 ND TZI 2.5-004-99 & 2.5-005-99: System Classification & Evaluation

The automated system classification and security evaluation criteria are continuously verified against the defined target profile. Instead of periodic manual assessments, the CMDB mechanism ensures that any architectural change triggers a re-evaluation of the system class (e.g., Class 2 or 3), ensuring that the protection profile remains consistently aligned with the nature of the processed data. This continuous classification guarantees that the system never inadvertently drifts into a non-compliant state due to infrastructure modifications.

2.2.4 ND TZI 3.6-006-24: Critical State Registries

The architecture fully supports the strict baseline requirements for critical state registries and judicial systems. It guarantees exceptional high availability (HA) across all nodes and mandates deep cryptographic integrity of evidentiary data utilizing national cryptographic algorithms (DSTU 4145-2002 for digital signatures, DSTU 7564-2014 for hashing), fulfilling the most stringent requirements for electronic governance. Compliance with this standard ensures the legal validity of electronic documents processed within the ERP system.

2.2.5 ND TZI 2.5-008-02: Confidential Information Protection

The system strictly adheres to the requirements for protecting confidential and restricted state information. The dynamic categorization mechanism evaluates the sensitivity of each data asset and dictates the requisite level of cryptographic segregation and physical protection (e.g., mandating air-gapped environments or specific HSM usage) required to legally process that data. The classification matrix automatically enforces the principle of least privilege, isolating highly sensitive segments away from standard user workflows.

2.2.6 ND TZI 2.5-010-03: Web Application Protection

Protection of web-facing applications from unauthorized access and malicious exploitation is handled proactively. The network profiles (`net.ex`) explicitly declare the placement and configuration of Web Application Firewalls (WAF) and deep packet inspection (DPI) mechanisms. Coupled with the ABAC filters, this ensures that web vulnerabilities are mitigated at the network boundary before reaching the application logic. The defense-in-depth approach nullifies common web exploitation vectors prior to authentication.

2.2.7 ISO/IEC 27001:2022 & DSTU ISO/IEC 27001:2015: ISMS Alignment

The entire CMDB-driven approach aligns perfectly with the core tenets of an Information Security Management System (ISMS). By treating the inventory, risk assessment, and access control matrices as live code, the system intrinsically

supports the ISO requirements for continuous improvement (Clause 10), comprehensive asset management (Annex A.8), and stringent logical access controls (Annex A.9). This programmatic integration effectively transforms the ISMS from a theoretical framework into an operational enforcement mechanism.

By transforming compliance into code, the CMDB guarantees that the operational reality of the infrastructure is continuously synchronized with the certified KSZI documentation.

3 Hierarchical Security Profiles (L1, L2, L3)

The system supports the automated construction of KSZI security profiles based on the regulatory and legal acts in the field of technical protection of information (TZI NPA). This automates documentation generation and the mapping of legislative requirements to technical settings. All certificates are issued with OID imprints of their respective security profiles.

The architecture is divided into three levels of profiles:

3.1 L1: Basic Security Profiles

These profiles define the fundamental sets of controls required by the regulations.

- **SECURITY POLICIES**¹
- **FULL DIRECTORY (950)**²
- **OPEN CONFIDENTIAL (126)**³
- **OFFICIAL (155)**⁴

3.2 L2: Industry Profiles

Industry-specific adaptations that expand upon the baseline controls to meet the requirements of specific sectors.

- **COURT INDUSTRY PROFILE**⁵: Industry security profile for the judicial system. It describes an extended set of baseline controls for processing sensitive information in state registries and courts, taking into account the requirements for high availability and data integrity based on ND TZI 3.6-006-24.
- **THE DIGITAL UKRAINIAN GOVERNMENT INDUSTRY PROFILE**⁶: Industry security profile for the Ministry of Digital Transformation of Ukraine.

3.3 L3: Target Security Profiles

Specific implementation targets for individual systems and components.

- **ERP/1 SECURITY TARGET**⁷: Target profile for the ERP/1 telecommunications system. Describes the implementation of Attribute-Based

¹<https://ca.n2o.dev/priv/security-profiles.pdf>

²https://ca.n2o.dev/priv/bible_profile.pdf

³https://ca.n2o.dev/priv/legal_l1_profile_409.pdf

⁴https://ca.n2o.dev/priv/legal_l1_profile_419.pdf

⁵https://ca.n2o.dev/priv/legal_l2_court_profile.pdf

⁶<https://ca.n2o.dev/priv/digital-profile.pdf>

⁷https://ca.n2o.dev/priv/legal_l3_profile_erp.pdf

Access Control (ABAC), information flow management (BPE), Public Key Infrastructure (PKI), and reliable auditing (KVS) for securing critical business processes.

- **X.509 CMS MESSAGING SECURITY TARGET⁸**: Target profile for corporate messenger systems. Based on X.509 and CMS (Cryptographic Message Syntax) cryptographic protocols, providing end-to-end encryption (E2EE), strict authentication, and non-repudiation for legally significant communications.
- **VPN SECURITY TARGET⁹**: Target profile for Virtual Private Network (VPN) and PKI infrastructures. Defines mechanisms for tunneling, node authentication (SC-8), and network traffic protection at the transport layer to secure communication channels against interception and modification.

4 Segregation of Duties: The Two-Stage KSZI Certification Process

According to the regulatory framework of Ukraine (e.g., ND TZI 2.6-001-11) and best global practices (the *Maker/Checker* principle), building and certifying a Comprehensive Information Security System (KSZI) is strictly a **two-stage procedure**. It requires the involvement of two completely independent licensed providers to eliminate any conflict of interest.

- **Stage 1: The Developer (Provider 1)**. The first provider performs the risk assessment, inspects the environment, and creates the "technical instructions" — the **Target Security Profile (Technical Specification)**. This provider is also responsible for the physical implementation of the security architecture: configuring cryptography, setting up the Reference Monitor (AC-25), installing certificates, and delivering the system into trial operation.
- **Stage 2: The Expertise Organizer (Provider 2)**. The second provider receives the Technical Specification from the Developer and designs the **Expertise Program**. This provider conducts an independent technical audit, instrumental testing, and live verification of all implemented controls. Upon successful verification, they issue the Expert Conclusion for the State Service of Special Communications and Information Protection (DSSZZI).

This segregation guarantees that the organization creating the security profiles and writing the Elixir CMDB structures is legally and practically distinct from the organization auditing and approving them.

⁸https://ca.n2o.dev/priv/chat_profile.pdf

⁹https://ca.n2o.dev/priv/vpn_profile.pdf

5 Programmatic Security Profiles

The following sections provide the complete execution traces of the CMDB profile extraction for the "ERP" system. These outputs demonstrate how the infrastructure is documented, maintained, and continuously monitored.

5.1 Risk Assessment (CA.PRO.risk)

The risk taxonomy enumerates the identified threats and binds them to the corresponding security control families.

```
iex> CA.PRO.risk("ERP")
[
  {"RISK-OS-01", "Вразливості Active Directory (Kerberoasting, Pass-the-Hash, Golden Ticket)", ["AC", "IA", "SC"]},
  {"RISK-OS-02", "Зловживання WMI та PowerShell (Fileless-методи)", ["SI", "SC", "CM"]},
  {"RISK-OS-03", "Вразливості на рівні ядра (BYOVD, Ring 0)", ["SI", "CM"]},
  {"RISK-OS-04", "Маніпуляція маркерами доступу (Token Stealing)", ["AC", "AU"]},
  {"RISK-OS-05", "Некоректні дозволи NTFS / Share (Orphaned SIDs)", ["AC", "CM"]},
  {"RISK-OS-06", "Підвищення привілеїв Linux (Kernel, SUID, Dirty COW)", ["AC", "SI"]},
  {"RISK-OS-07", "Втеча з контейнерів Docker/Kubernetes", ["SC", "CM"]},
  {"RISK-OS-08", "Зловживання eBPF (прихований моніторинг)", ["AU", "SI"]},
  {"RISK-OS-09", "Ін'єкції динамічних бібліотек (LD_PRELOAD)", ["SI", "CM"]},
  {"RISK-OS-10", "Вразливості ПАМ (обхід автентифікації)", ["IA", "AC"]},
  {"RISK-OS-11", "Обхід XProtect / Gatekeeper / SIP (macOS)", ["CM", "SI"]},
  {"RISK-OS-12", "Компрометація macOS Keychain", ["IA", "SC"]},
  {"RISK-OS-13", "TCC Bypass & Spyware (macOS)", ["SI", "PE"]},
  {"RISK-OS-14", "Dyld Hijacking (macOS)", ["SI"]},
  {"RISK-OS-15", "Обхід Pointer Authentication PAC (Apple Silicon)", ["SI", "SA"]},
  {"RISK-CRY-01", "Пост-квантові загрози SNL (Store Now, Decrypt Later)", ["SC", "RA", "SA"]},
  {"RISK-CRY-02", "Атаки сторонніми каналами (DPA, таймінг, EM)", ["SC", "PE", "SA"]},
  {"RISK-CRY-03", "Fault Injection (Glitching, Voltage Drop)", ["PE", "SI", "SC"]},
  {"RISK-CRY-04", "Компрометація ПАК «Грядя» (IIT HSM)", ["PE", "SC", "AC"]},
  {"RISK-CRY-05", "Екстракція ключів з HKI e-Токен (IIT)", ["PE", "SC"]},
  {"RISK-CRY-06", "Вразливості ASN.1 парсерів X.509 / CMS", ["SI", "SA"]},
  {"RISK-CRY-07", "Вразливості криптобібліотек ДСТУ (Калина, Купина, Padding Oracle)", ["SA", "SI"]},
  {"RISK-CRY-08", "Недостатня ентропія генератора псевдовипадкових чисел (PRNG)", ["SC"]},
  {"RISK-CRY-09", "Втрата або перехоплення PIN-кодів HSM (кейлогери)", ["IA", "AT", "PE"]},
  {"RISK-CRY-10", "Фізична деструкція носіїв «Автор» (CryptoCard)", ["PE", "MP"]},
  {"RISK-CRY-11", "Вразливості CCID драйверів токенів (ескаляція привілеїв)", ["SI", "CM"]},
  {"RISK-CRY-12", "Підміна сесій PKCS#11 (MitM між ПЗ ЦСК та HSM)", ["SC", "SI"]},
  {"RISK-NET-01", "BGP Hijacking & Route Leaks (підміна анонсів AS)", ["SC", "SI"]},
  {"RISK-NET-02", "Атаки L2 (VLAN Hopping, ARP Spoofing, STP атаки)", ["SC", "AC"]},
  {"RISK-NET-03", "Вразливості IPSec / VPN (IKE downgrade, PSK витік)", ["SC", "IA"]},
  {"RISK-NET-04", "DDoS (Slowloris, SYN Flood, ампліфікація DNS/NTP)", ["SC", "IR"]},
  {"RISK-NET-05", "Компрометація Wi-Fi (KRACK, PMKID, Evil Twin)", ["SC", "IA"]},
  {"RISK-NET-06", "Вразливості DNSSEC (DNS Spoofing, помилки конфігурації)", ["SC", "SI"]},
  {"RISK-NET-07", "Відкриті інтерфейси управління (SNMPv1/v2, Telnet, REST API)", ["CM", "AC", "SC"]},
  {"RISK-INF-01", "Компрометація BMC (IPMI, iDRAC, iLO)", ["AC", "SC"]},
  {"RISK-INF-02", "Вразливості Firmware / UEFI Bootkits", ["SI", "SA"]},
  {"RISK-INF-03", "Атаки на мікроархітектуру CPU (Spectre, Meltdown)", ["SI", "SC"]},
  {"RISK-INF-04", "Cold Boot & Rowhammer атаки на пам'ять", ["PE", "SI"]},
  {"RISK-INF-05", "Відмова дискових масивів SAN/NAS (Split-brain)", ["CP", "SI"]},
  {"RISK-INF-06", "Електромагнітне випромінювання TEMPEST", ["PE", "SC"]},
  {"RISK-INF-07", "Відмова інженерних систем (UPS, дизель, чиллер, пожежогасіння)", ["PE", "CP"]},
  {"RISK-PER-01", "Spear Phishing & Whaling (цільовий фішинг адміністраторів)", ["AT", "IR", "SI"]},
  {"RISK-PER-02", "Watering Hole Attacks (компрометація профільних ресурсів)", ["SI", "AT"]},
  {"RISK-PER-03", "Інсайдерський саботаж та експільтрація (логічні бомби)", ["PS", "AU", "AC"]},
  {"RISK-PER-04", "Pretexting / Baiting / Tailgating (фізичний доступ)", ["AT", "PE", "PS"]},
  {"RISK-PER-05", "Credential Stuffing (словники та бази паролів)", ["IA", "AT"]},
  {"RISK-SYNC-01", "Race Condition (стан гонитви у спільних ресурсах)", ["SI", "SA"]},
  {"RISK-SYNC-02", "TOCTOU (Time-of-Check to Time-of-Use)", ["SI", "AC"]},
  {"RISK-SYNC-03", "NTP Spoofing (десинхронізація часу)", ["SC", "AU", "SI"]},
  {"RISK-SYNC-04", "Split-Brain у кластерах СУБД", ["CP", "SI"]},
  {"RISK-SYNC-05", "Replication Lag (вікно доступу до застарілих даних)", ["SI", "SC"]},
  {"RISK-DAT-01", "Втрата резервних копій (Ransomware, Backup Corruption)", ["CP", "MP", "SI"]},
```

```
{ "RISK-DAT-02", "Витік електронних судових справ (несанкціонований доступ)", [ "AC", "SC", "PE" ] }
```

5.2 System Software Components (CA.PRO.sys)

The system inventory documents all OS, middleware, platform, and application-level software components running in the environment, satisfying NIST CM-8 and PM-5.

```
iex> CA.PRO.sys("ERP")
[
  { "SYS-OS-01-UAL", "UA Linux 24.04 LTS (ДКТУ-hardened, SELINUX Enforcing) (24.04 LTS)", [] },
  { "SYS-OS-01-WIN", "Windows Server 2025 Datacenter (NATO STIG + DISA hardened) (2025 Datacenter)", [] },
  { "SYS-OS-01-ESX", "VMware ESXi 8.0 Update 3 (vSphere Foundation) (8.0 U3)", [] },
  { "SYS-OS-02-W11", "Windows 11 Pro 24H2 (DISA STIG + Windows Defender Credential Guard) (24H2 (Build 26100))", [] },
  { "SYS-OS-02-UAL", "UA Linux Desktop 24.04 LTS (ДКТУ, GNOME Hardened) (24.04 LTS Desktop)", [] },
  { "SYS-APP-00-ERL", "Erlang/OTP 27.3 (SMP, BEAM VM, distribution TLS) (27.3)", [] },
  { "SYS-APP-00-ELX", "Elixir 1.18.3 (N20, NITRO, FORM, Bandit) (1.18.3)", [] },
  { "SYS-APP-00-EMQ", "EMQ X 2.12 (MQTT 5.0 / MQTT-SN, Erlang/OTP cluster) (2.12)", [] },
  { "SYS-SYNRC-CA", "Сертифікати (7.4)", [] },
  { "SYS-SYNRC-VPN", "Тунелі (1.0)", [] },
  { "SYS-SYNRC-LDAP", "Директорія (1.0)", [] },
  { "SYS-SYNRC-CHAT", "Комунікатор (4.2)", [] },
  { "SYS-SYNRC-BPMN", "Процеси (6.11)", [] },
  { "SYS-SYNRC-MQTT", "Брокер (2.12)", [] },
  { "SYS-SYNRC-KVS", "Сховище (10.0)", [] },
  { "SYS-SYNRC-WS", "Фреймворк (11.0)", [] },
  { "SYS-SYNRC-FORM", "Форми (1.3)", [] },
  { "SYS-SYNRC-ASN1", "Компілятор (1.0)", [] },
  { "SYS-SYNRC-ABAC", "Контроль (1.0)", [] },
  { "SYS-ERP-EDU", "Освіта (1.0)", [] },
  { "SYS-ERP-HEALTH", "Здоров'я (1.0)", [] },
  { "SYS-ERP-MAIL", "Документи (1.0)", [] },
  { "SYS-ERP-ACC", "Облік (1.0)", [] },
  { "SYS-ERP-WAREHOUSE", "Склад (1.0)", [] },
  { "SYS-ERP-CART", "Реєстри (1.0)", [] },
  { "SYS-APP-01-IIT", "ІІТ Користувач ЦСК-1 (бібліотека «ІІТ Gryada-301») (3.0.1)", [] },
  { "SYS-APP-01-CIP", "Сайффер HSM Middleware (PKCS#11 + CMS + TSP клієнт) (2.8)", [] },
  { "SYS-APP-01-SIGN", "Автор Е-Підпис Сервер (batch signing, LTV, XAdES-BES) (5.2)", [] },
  { "SYS-APP-02-WZ", "Wazuh 4.9 SIEM/XDR (OSSEC-based, FIM, compliance CIS/NIST) (4.9)", [] },
  { "SYS-APP-02-ZBX", "Zabbix 7.2 (active agents, encrypted PSK transport, alerting) (7.2 LTS)", [] },
  { "SYS-DB-01-PG", "PostgreSQL 17.2 (TDE + pgAudit + pg_partman) (17.2)", [] },
  { "SYS-DB-01-ORA", "Oracle Database 23ai (Advanced Security Option, TDE, Vault) (23ai (23.5))", [] },
  { "SYS-DB-02-RDS", "Redis 7.4 (TLS 1.3, ACL, persistence RDB+AOF) (7.4)", [] },
  { "SYS-INF-01-VBR", "Veeam Backup & Replication 12.3 (immutable backups, SureBackup) (12.3)", [] },
  { "SYS-INF-01-BCL", "Bacula Community 15.0 (offline tape + air-gapped archive) (15.0)", [] },
  { "SYS-MW-01-NGX", "Nginx 1.27 (TLS 1.3 only, OCSP Stapling, CT Logs, HSTS) (1.27)", [] },
  { "SYS-MW-01-HAP", "HAProxy 3.0 (HA pair, health checks, rate limiting) (3.0 LTS)", [] },
  { "SYS-MW-02-AD", "Active Directory Domain Services 2025 (LAPS v2, Protected Users, Tiering) (Windows Server 2...)", [] },
  { "SYS-MW-02-IPA", "FreeIPA 4.12 (Kerberos V, OTP, CA sub-ідентифікатор) (4.12)", [] }
]
```

5.3 Hardware Inventory (CA.PRO.inventory)

The hardware inventory explicitly tracks physical assets, cryptographic modules (HSMs), network appliances, and storage arrays.

```
iex> CA.PRO.inventory("ERP")
[
  { "ERP-STG-01", "ERP-STG-2025-001", "5HT Technology AllFlash NVMe Array (Sapphire Rapids Storage Controller)",
    { "ERP-STG-02", "ERP-STG-2025-002", "5HT Technology AllFlash NVMe Array" },
    { "ERP-TAPE-01", "ERP-STG-2025-003", "HPE StoreEver MSL3040 Tape Library" },
  }
```

```

{"ERP-WS-01", "ERP-WS-2025-001", "5HT Technology Workstation Compact (Sapphire Rapids)"},
{"ERP-WS-02", "ERP-WS-2025-002", "5HT Technology Workstation Compact (Sapphire Rapids)"},
{"ERP-KZI-01", "ERP-KZI-2025-001", "IIT Gryada-301 PCIe HSM"},
{"ERP-KZI-02", "ERP-KZI-2025-002", "IIT Gryada-301 PCIe HSM"},
{"ERP-KZI-03", "ERP-KZI-2025-003", "Avtop CryptoCard Smart-01 (e-Токен, Смарт-карта)"},
{"ERP-NET-01", "ERP-NET-2025-001", "Cisco Catalyst 9500-48Y4C"},
{"ERP-NET-02", "ERP-NET-2025-002", "Cisco Catalyst 9500-48Y4C"},
{"ERP-NET-03", "ERP-NET-2025-003", "Cisco ASR 1002-HX Router"},
{"ERP-FW-01", "ERP-NET-2025-004", "Cisco Firepower 4145 NGFW (FTD 7.6)"},
{"ERP-FW-02", "ERP-NET-2025-005", "Cisco Firepower 4145 NGFW (FTD 7.6)"},
{"ERP-SRV-01", "ERP-2025-001", "5HT Technology Tristellar 3U"},
{"ERP-SRV-02", "ERP-2025-002", "5HT Technology Tristellar 3U"},
{"ERP-SRV-03", "ERP-2025-003", "5HT Technology Quadstellar 4U"},
{"ERP-SRV-04", "ERP-2025-004", "5HT Technology Quadstellar 4U"},
{"ERP-SRV-05", "ERP-2025-005", "5HT Technology Tristellar 3U"},
{"ERP-SRV-06", "ERP-2025-006", "5HT Technology Tristellar 3U"},
{"ERP-SRV-07", "ERP-2025-007", "5HT Technology Tristellar 3U"},
{"ERP-SRV-08", "ERP-2025-008", "5HT Technology Tristellar 3U"}
]

```

5.4 Role-Based Access Control (CA.PRO.roles)

The defined roles establish the baseline for the Attribute-Based Access Control (ABAC) and Role-Based Access Control (RBAC) mechanisms.

```

iex> CA.PRO.roles("ERP")
[
  {"ROLE-ADM-01", "Адміністратор безпеки", ["security_admin"]},
  {"ROLE-AUD-01", "Аудитор", ["auditor"]},
  {"ROLE-OPR-01", "Оператор реєстрації", ["reg_operator"]},
  {"ROLE-SYS-01", "Системний процес (Machine-to-Machine)", ["ocsp_service", "crl_generator"]},
  {"ROLE-SADM-01", "Глобальний суперадміністратор (root/administrator)", ["global_root_admin", "infra_super_user"]}
]

```

5.5 Data Categorization (CA.PRO.data)

Data categorization ensures that sensitive information (e.g., PII, keys) is stored in the appropriate encrypted and access-controlled repositories.

```

iex> CA.PRO.data("ERP")
[
  {"DATA-PUB-01", "Публічні сертифікати та CRL", "Public CDN / web server"},
  {"DATA-PUB-02", "Політики ЦСК (CPS, CP)", "Public web server"},
  {"DATA-PII-01", "Реєстр підписників (паспорти, ПНОКПП)", "Encrypted DB (PostgreSQL)"},
  {"DATA-PII-02", "Адресні та контактні дані підписників", "Encrypted DB (PostgreSQL)"},
  {"DATA-INT-01", "Внутрішні накази та регламенти", "Internal file server"},
  {"DATA-INT-02", "Журнали аудиту (SIEM logs)", "SIEM (Elasticsearch)"},
  {"DATA-KEY-01", "Кореневі та підпорядковані ключі ЦСК", "HSM (Грядя / IIT)"},
  {"DATA-KEY-02", "Паролі та секрети адміністраторів", "Password Manager (Vault)"},
  {"DATA-CRT-01", "Матеріали судових проваджень та ухвали", "Encrypted DB (Oracle / PostgreSQL)"},
  {"DATA-CRT-02", "Електронні докази (обмежений доступ)", "Encrypted storage (Scality RING)"},
  {"DATA-BKP-01", "Снапшоти БД та образи ВМ", "Tape Library (MSL3040)"},
  {"DATA-BKP-02", "Офлайн-архіви судових документів", "Air-gapped Tape (offline)"}
]

```

5.6 Business Processes (CA.PRO.proc)

The documentation of business processes connects operational workflows with their responsible actors, ensuring accountability.


```

iex> CA.PRO.proc("ERP")
[
  {"PROC-CERT-01", "Видача кваліфікованих сертифікатів", "Оператор реєстрації ЦСК"},
  {"PROC-OCSP-01", "Формування OCSP-відповідей (24/7)", "Автоматичний сервіс ЦСК"},
  {"PROC-AUDIT-01", "Логування та моніторинг подій безпеки", "Адміністратор безпеки / SIEM"},
  {"PROC-ROOT-01", "Церемонія генерації кореневого ключа", "Комісія ЦСК (Dual Control)"},
  {"PROC-DOC-01", "Реєстрація та розгляд судових справ", "Судова влада України / ДП ICC"},
  {"PROC-BKP-01", "Резервне копіювання та відновлення", "Адміністратор резервного копіювання"}
]

```

5.7 Network Architecture (CA.PRO.net)

The network segmentation profile details the logical separation of DMZ, internal, management, and air-gapped zones to prevent lateral movement.

```

iex> CA.PRO.net("ERP")
[
  {"NET-DMZ-01", "OCSP / CRL публічний ендпоінт", "публічна підмережа"},
  {"NET-DMZ-02", "Веб-портал ЦСК", "публічна підмережа"},
  {"NET-INT-01", "Сегмент серверів БД", "внутрішня підмережа БД"},
  {"NET-INT-02", "Сегмент робочих станцій операторів", "внутрішня підмережа АРМ"},
  {"NET-MGT-01", "VLAN IPMI / iLO адміністрування", "management VLAN"},
  {"NET-AIR-01", "Кореневий ЦСК (офлайн вузол)", "N/A"}
]

```

6 ERP/1: Відповідність повному стеку контролів NIST SP 800-53

Наступний розділ є повним поконтрольним науковим аналізом того, яким чином компоненти платформи ERP/1 (екосистема ERP.UNO, N20.DEV, SYNRC.COM) природно та архітектурно закривають вимоги NIST SP 800-53 Rev.5 та НД ТЗІ 2.3-025-24. Кожен продукт платформи є цільовим рішенням для конкретного домену безпеки, що забезпечує максимально органічне, без "на-тяжок виконання стандарту. Аналіз охоплює всі 20 сімейств контролів: AC, AT, AU, CA, CM, CP, IA, IR, MA, MP, PE, PL, PM, PS, PT, RA, SA, SC, SI, SR.

6.1 Клас AC: Управління доступом

6.1.1 zencrypted/ias: AC-2 — Управління обліковими записами

Сервер `ias` (Identity and Access Server) є центральним Identity Provider (IdP) платформи, який реалізує весь життєвий цикл облікових записів через єдиний програмний інтерфейс. На відміну від розрізнених LDAP-директорій, `ias` оперує декларативними профілями користувачів, безпосередньо пов'язаними з реєстром ролей `roles.ex`.

AC-2(1) — Автоматизоване управління обліковими записами системи. `ias` підтримує SCIM 2.0 (System for Cross-domain Identity Management) для автоматичної синхронізації стану облікових записів між підсистемами. При надходженні події від HR-модуля (наприклад, ERP/EDU або ERP/HEALTH), `ias` автоматично виконує provisioning або de-provisioning без ручного втручання, гарантуючи відповідність вимогам Joiner-Mover-Leaver (JML).

AC-2(2) — Видалення тимчасових та екстрених облікових записів. Тимчасові облікові записи у `ias` мають обов'язкові поля `expires_at` та `account_type: :temporary`. Фоновий планувальник (реалізований засобами Erlang/OTP `:timer`) щогодини інспектує базу та автоматично деактивує протерміновані записи. Встановлення часу існування є обов'язковим параметром при створенні тимчасового запису.

AC-2(3) — Деактивація неактивних облікових записів. Сервер `ias` зберігає мітку `last_seen_at` для кожного сеансу. Якщо значення перевищує конфігурований поріг (за замовчуванням 90 днів), запис переводиться у стан `:inactive` з автоматичним відправленням сповіщення адміністратору безпеки.

AC-2(4) — Дії при автоматизованому аудиті. Будь-яка зміна стану облікового запису (створення, зміна привілеїв, деактивація, видалення) генерує підписаний запис у журналі аудиту `kvs` через event sourcing. Це забезпечує незмінний, криптографічно захищений слід усіх адміністративних дій.

AC-2(5) — Вихід із системи за відсутності активності. `ias` централізовано керує тривалістю сесій. Налаштування `session_idle_timeout`

є глобальним параметром і може бути перевизначений на рівні ролі (наприклад, для адміністраторів — жорсткіший ліміт 15 хвилин).

АС-2(6) — Динамічне управління привілеями. Оскільки `ias` інтегрований з `erpuno/abac`, привілеї є не статичними атрибутами профілю, а динамічно обчислюваними рішеннями Policy Decision Point. Це означає, що підвищені привілеї (наприклад, режим адміністратора для критичних операцій) активуються тільки на час конкретного сеансу та для конкретного ресурсу.

АС-2(7) — Схеми, засновані на ролях. Інтеграція `ias` з `roles.ex` дозволяє ієрархічно організовувати ролі (RBAC). Рольові шаблони наслідуються: роль `auditor` автоматично отримує всі права батьківської ролі `read_only`, не потребуючи дублювання правил.

АС-2(8) — Динамічне управління обліковими записами. Для сервісних облікових записів (machine-to-machine) `ias` підтримує OAuth 2.0 Client Credentials з короткоживучими токенами (TTL 15 хвилин). Сервіси не мають постійного пароля, що унеможливило витік довгострокових секретів.

АС-2(9) — Обмеження на використання спільних облікових записів. Архітектура `ias` не дозволяє створення "спільних" (shared) облікових записів за замовчуванням. Кожен суб'єкт — особа або сервіс — має унікальний криптографічний ідентифікатор, що зв'язаний з сертифікатом X.509, виданим `synrc/ca`.

АС-2(10) — Зміна даних спільних та групових облікових записів. Для технічних групових записів (наприклад, `ocsp_service`) `ias` реалізує механізм "ротации секрету" через кожну зміну складу групи, автоматично генеруючи нову пару ключів через `synrc/ca`.

АС-2(11) — Умови використання. При вході в систему `ias` перевіряє актуальність прийнятих правил використання. Якщо версія `terms_of_service_version` у профілі не збігається з поточною, доступ блокується до підтвердження нових умов.

АС-2(12) — Моніторинг нетипового використання облікових записів. Поведінкові метрики (частота запитів, географія, нетипові години) агрегуються `ias` та передаються до SIEM (Wazuh). При перевищенні поведінкового базового рівня автоматично створюється інцидент в `erpuno/itsm`.

АС-2(13) — Деактивація облікових записів осіб з високим рівнем ризику. Інтеграція з SIEM дозволяє `ias` отримувати webhook-сигнали про компрометацію. При отриманні сигналу `high_risk_account_detected` відповідний профіль переводиться у `:suspended` протягом секунди, незалежно від поточних активних сесій.

6.1.2 zencrypted/ias: АС-7 — Невдалі спроби входу

АС-7 (базовий контроль). `ias` веде лічильник невдалих спроб автентифікації з прив'язкою до суб'єкта та IP-адреси. Після конфігурованого порогу (за замовчуванням 5 спроб за 10 хвилин) обліковий запис тимчасово блокується (account lockout) з автоматичним сповіщенням адміністратора.

АС-7(2) — Очищення або стирання мобільного пристрою. При отриманні сигналу від MDM-системи (Mobile Device Management) про крадіжку або компрометацію пристрою, `ias` негайно відкликає всі токени та сертифікати, асоційовані з цим пристроєм, через механізм OSCP revocation у `synrc/ca`.

6.1.3 `synrc/ca`: АС-3 — Забезпечення доступу

Модуль `synrc/ca` реалізує Reference Monitor (АС-25) — централізований контрольний механізм, який верифікує кожне звернення до захищеного ресурсу на основі X.509-сертифікатів та ABAC-політик.

АС-3(3) — Мандатне управління доступом. `synrc/ca` підтримує мітки класифікації даних (Data Labels) у розширеннях X.509-сертифікатів. Це дозволяє реалізувати мандатний (Mandatory Access Control) принцип: сертифікат із рівнем допуску `confidential` не може отримати доступ до ресурсу, позначеного `secret`, навіть якщо RBAC-правило це формально дозволяє.

АС-3(4) — Дискреційне управління доступом. Власники ресурсів можуть делегувати права доступу через механізм атрибутованих токенів `ias`, що реалізує класичну модель DAC (Discretionary Access Control). Делегування завжди обмежене рамками власних повноважень делегуючого суб'єкта.

АС-3(7) — Управління доступом на основі ролей. RBAC реалізований на рівні розширень X.509, де поле `SubjectAlternativeName` містить URN ролей. Це означає, що роль криптографічно прив'язана до особи та підтверджена цифровим підписом кореневого ЦСК, унеможливаючи підробку або підміну ролі.

АС-3(10) — Перевірка доступу на основі заявок. Для сервісів, що використовують JWT або SAML, `ias` генерує підписані заявки (`claims`) з терміном дії. `synrc/ca` виступає Authority, що видає короткострокові assertion-токени, верифікація яких не потребує запиту до IdP (stateless verification).

АС-3(11) — Вимоги до ізоляції програм. Ізоляція між тенантами ERP/1 (наприклад, між різними судами або відомствами) реалізована на рівні `namespace` у Kubernetes та унікальних корневих сертифікатів для кожного тенанта, виданих `synrc/ca`.

АС-3(12) — Атрибути доступу. Рішення про доступ `abac` враховує набір атрибутів: `subject.role`, `subject.clearance`, `resource.classification`, `action.type`, `environment.time`, `environment.network_zone`. Це забезпечує контекстно-залежний доступ відповідно до принципу Zero Trust.

АС-3(13) — Атрибути суб'єкта та об'єкта. Атрибути суб'єктів зберігаються у `ias` та `synrc/ca`, атрибути ресурсів — у метаданих KVS. `abac` отримує їх у момент прийняття рішення, що гарантує актуальність атрибутів навіть при частих змінах контексту.

АС-3(15) — Дискреційний та обов'язковий доступ. Система підтримує одночасну дію двох моделей: MAC (на основі класифікаційних міток

у X.509) та DAC (делегування через *ias*). Пріоритет завжди за MAC: якщо мандатна мітка забороняє доступ, DAC-правило не може його відкрити.

6.1.4 *synrc/bpmn*: AC-4 — Управління інформаційними потоками

BPMN-рушій *synrc/bpmn* є центральним оркестратором бізнес-процесів, і саме через нього проходять всі інформаційні потоки між компонентами платформи.

AC-4 (базовий). Кожен перехід даних між задачами бізнес-процесу (BPMN Task) є підконтрольним подією. *bpmn* реалізує "інформаційні шлюзи"— вузли процесу, що перевіряють класифікацію даних перед передачею між сегментами мережі або між тенантами.

AC-4(1) — Атрибути безпеки об'єкту. Артефакти (документи, справи), що передаються між задачами, мають обов'язковий атрибут *data_classification*. BPMN-шлюз відхиляє передачу, якщо класифікація артефакту не збігається з дозволим рівнем цільового сегменту процесу.

AC-4(4) — Перевірка вмісту даних. На межах між організаційними одиницями *bpmn* виконує схемну валідацію переданих документів (JSON Schema, XSD) та верифікацію підписів CMS/XAdES перед продовженням процесу.

6.1.5 *eruno/abac*: AC-5 та AC-6 — Розмежування та мінімізація повноважень

AC-5 — Розмежування обов'язків. *abac* реалізує Separation of Duties (SoD) через декларативні XACML-подібні правила, що вказують множини взаємовиключних ролей (SSD: Static Separation of Duties). Наприклад, одна й та сама особа не може мати ролі *initiator* та *approver* для фінансових транзакцій. Правила SoD верифікуються не лише при виконанні дії, але й при призначенні ролі — система відхиляє призначення, що призвело б до конфлікту.

AC-6 — Мінімізація повноважень. Базовий принцип *abac*: за замовчуванням доступ заборонений (Default Deny). Дозвіл видається лише за наявності явного, позитивного відповідного правила. Правила мають мінімально необхідну область застосування (*scope*) — вони прив'язані до конкретного ресурсу, дії та контексту.

AC-6(1) — Надання привілеїв на основі атрибутів. Замість статичного надання прав, *abac* обчислює привілеї динамічно на основі поточних атрибутів суб'єкта та контексту. Підвищені права (наприклад, операції в режимі BreakGlass) є тимчасовими та автоматично відкликаються після завершення критичної операції.

AC-6(2) — Non-Privileged Access for Non-Security Functions. *abac* забезпечує, що адміністративні ролі (наприклад, *security_admin*) за замовчуванням не мають доступу до бізнес-функцій (судові справи, медичні дані). Адміністратор безпеки адмініструє *систему*, а не *дані* системи.

АС-6(3) — Мережевий доступ до привілейованих команд. Привілейовані команди (перезапуск сервісів, зміна конфігурації) доступні лише через виділений Management VLAN, а не через загальний мережевий інтерфейс. abas перевіряє атрибут `environment.network_zone` у кожному запиті.

АС-6(4) — Розмежування функцій між суб'єктами. Наприклад, оператор реєстрації ЦСК може *подати* запит на сертифікат, але лише адміністратор ЦСК може його *підписати*. Це двоетапне затвердження (Maker/Checker) жорстко закодовано у BPMN-процесі та АВАС-правилах.

АС-6(5) — Привілейовані облікові записи. Список привілейованих облікових записів (наприклад, `global_root_admin`) визначений у `roles.ex` та підлягає щомісячному аудиту (контроль АС-2(12)). Кількість суб'єктів у цій групі мінімізована та задокументована.

АС-6(7) — Перегляд привілейованих ролей. Раз на квартал `ias` автоматично генерує звіт `privileged_access_review_report` із переліком усіх суб'єктів, що мають підвищені права, датами останнього входу та аномаліями. Звіт надсилається CISO.

АС-6(9) — Аудит використання привілейованих функцій. Кожне виконання привілейованої дії логується окремим записом у `kvs` з повним контекстом: суб'єкт, роль, дія, час, IP, хеш виконаної команди. Ці записи є *незмінними* завдяки `append-only` природі KVS.

АС-6(10) — Заборона непривілейованим користувачам виконувати привілейовані функції. Технічно реалізується через поєднання АВАС-правил та криптографічних мандатів X.509: привілейовані API-ендпоінти вимагають наявності конкретного OID розширення у сертифікаті, яке видається лише при явному призначенні привілейованої ролі.

6.2 Клас АТ: Навчання та обізнаність

6.2.1 `synrc/ca`: АТ-2, АТ-3 — Навчання з питань безпеки

`synrc/ca` виступає як платформа для проведення рольових тренінгів (АТ-3). Зокрема, для операторів ЦСК реалізований симуляційний режим, де всі операції підпису відбуваються на тестовому HSM з тестовими ключами. Це дозволяє відпрацьовувати критичні процедури (Церемонія Ключа, OSCP) без ризику для виробничого середовища.

АТ-2(2) — Фішингові симуляції. Інтеграція `ias` з поштовим модулем ERP/MAIL дозволяє автоматично відправляти тестові фішингові листи та реєструвати відповідь користувачів. Результати автоматично прив'язуються до профілів у `ias` та впливають на оцінку ризику суб'єкта.

6.3 Клас АУ: Аудит та підзвітність

6.3.1 `zencrypted/ias`: АУ-2, АУ-3, АУ-6, АУ-12

АУ-2 — Події аудиту. `ias` є першоджерелом більшості подій безпеки: вхід/вихід, невдалі автентифікації, зміни профілів, делегування привілеїв.

Перелік подій визначений у конфігурації та відповідає вимогам НД ТЗІ 2.3-025-24 щодо обов'язкового журналювання.

AU-3 — Вміст записів аудиту. Кожен запис аудиту `ias` містить: `timestamp` (з точністю до мілісекунди, синхронізований з NTP), `subject_id`, `event_type`, `resource_id`, `action`, `outcome` (success/failure), `source_ip`, `session_id`, `signature` (HMAC підпис запису).

AU-6 — Аналіз та звітність про аудит. Журнали `ias` автоматично пересилаються у SIEM (Wazuh) через захищений syslog. Wazuh застосовує кореляційні правила NIST та CIS для виявлення аномалій та генерації алертів.

AU-9 — Захист інформації аудиту. Записи аудиту зберігаються у `kvs` з хешуванням DSTU 7564-2014 (Кирупа). Будь-яке несанкціоноване змінення запису детектується при наступній верифікації ланцюга.

AU-10 — Незаперечність (Non-Repudiation). Критичні події (підпис документів, затвердження, видача сертифікатів) фіксуються з TSP-мітками часу (RFC 3161) від довіреного постачальника TSA, що гарантує юридичну силу доказів в судовому провадженні.

AU-12 — Генерація записів аудиту. `ias` генерує записи аудиту в режимі реального часу для всіх сконфігурованих подій. Відмова від журналювання (наприклад, через переповнення буфера) призводить до відмови самої операції — принцип "Fail Secure".

6.4 Клас СА: Оцінка, авторизація та моніторинг

6.4.1 `synrc/ca`: СА-2, СА-6, СА-7, СА-8, СА-9

СА-2 — Оцінка заходів безпеки та конфіденційності. `synrc/ca` автоматизує збір доказів відповідності через CMDB API. Перед кожним аудитом (державна експертиза ДССЗЗІ) виконується `mix run -e 'CA.TeX.generate()'`, що формує повний пакет документації з актуального стану системи.

СА-6 — Авторизація платформи. Авторизація системи формалізована через L3-профіль безпеки (`legal_l3_profile_erp.pdf`), сформований програмно з CMDB та підписаний. Оновлення авторизації відбувається при будь-якій суттєвій зміні архітектури.

СА-7 — Безперервний моніторинг. Постійний моніторинг реалізований через тріаду: Wazuh SIEM (події безпеки), Zabbix (доступність та продуктивність), `synrc/ca` CMDB (відповідність конфігурації). Відхилення від зафіксованого базового стану (CMDB drift) негайно генерує інцидент у `itsm`.

СА-8 — Тестування проникнення. Регулярні пентести (принаймні щорічно) охоплюють всі компоненти ERP/1. Результати формалізуються як CMDB-записи ризиків та відстежуються через Plan of Action & Milestones (POA&M — контроль РМ-4).

СА-9 — Внутрішні системні з'єднання. Усі внутрішні з'єднання між сервісами ERP/1 авторизуються через mTLS (mutual TLS) з сертифікатами від `synrc/ca`. Неавторизоване або несертифіковане з'єднання технічно

неможливе.

6.5 Клас CM: Конфігураційне управління

6.5.1 `synrc/ca` CMDB: CM-2, CM-3, CM-6, CM-7, CM-8, CM-9

CM-2, CM-3 — Базова конфігурація та контроль змін. Еталонна конфігурація всіх компонентів зафіксована у CMDB Elixir-модулях (`hw.ex`, `sys.ex`, `net.ex`). Кожна зміна у виробничому середовищі повинна спочатку відобразитися у відповідному CMDB-файлі та пройти Code Review у Git. Відхилення від еталону (configuration drift) детектується Wazuh FIM (File Integrity Monitoring).

CM-6 — Налаштування конфігурації. Усі сервіси ERP/1 запускаються зі строгими безпечними конфігураційними шаблонами (Security Hardening Baselines): UA Linux ДСТУ-hardened, SELinux Enforcing, Windows Server DISA STIG. Відхилення від базових налаштувань технічно заблоковані через механізми SCM (Puppet/Ansible).

CM-7 — Мінімальна функціональність. Кожен сервіс ERP/1 запускається лише з тими компонентами, що необхідні для виконання його функцій. Непотрібні модулі, протоколи та порти відключені. Перелік дозволених компонентів задокументований у відповідному `sys.ex` записі CMDB.

CM-8 — Інвентаризація компонентів системи. CMDB `synrc/ca` є "живим" реєстром всіх апаратних, програмних та мережевих компонентів. Кожен ресурс має унікальний інвентаризаційний номер, прив'язаний до криптографічного сертифіката та зафіксований у `hw.ex` або `sys.ex`.

CM-9 — План конфігураційного управління. Замість окремого текстового документа, план КМ безпосередньо закодований у Git-репозиторії: pipeline CI/CD, Elixir CMDB-модулі, Ansible-плейбуки та цей PDF-звіт разом утворюють повний, само-верифікований план управління конфігурацією.

6.6 Клас CP: Планування безперервності

6.6.1 `erlang/otp`: CP-2, CP-7, CP-9, CP-10

CP-2 — План безперервності. Erlang/OTP є фундаментом відмовостійкості ERP/1. Архітектура Supervision Tree гарантує автоматичний перезапуск будь-якого відмовилого процесу. На рівні кластера, наявність мінімум трьох вузлів (quorum) забезпечує доступність навіть при відмові одного вузла.

CP-7 — Альтернативний майданчик обробки. Erlang/OTP підтримує "гаряче" перемикання (hot failover) між вузлами кластера без втрати поточних сесій. Розподілений реєстр процесів (`:pg` або через `synrc/kvs`) дозволяє іншому вузлу взяти на себе обробку після відмови первинного.

CP-9 — Резервне копіювання інформаційної системи. Дані `kvs` безперервно реплікуються на всі вузли кластера (синхронна реплікація Mnesia/RocksDB).

Щодобово виконується знімок (snapshot) на стрічковий архів (HPE StoreEver) для офлайн-зберігання.

СР-10 — Відновлення інформаційної системи. Процедури відновлення відпрацьовані у рамках тренінгів (АТ-3) на ізольованому середовищі. Вбудована функція `:hot_code_upgrade` дозволяє оновлювати компоненти без зупинки системи, що мінімізує RTO (Recovery Time Objective).

6.7 Клас ІА: Ідентифікація та автентифікація

6.7.1 `synrc/ca + zencrypted/ias`: ІА-2, ІА-5, ІА-8

ІА-2 — Ідентифікація та автентифікація організаційних користувачів. `ias` реалізує суворий MFA: перший фактор — сертифікат X.509 (смарт-карта або HSM-токен ІІТ Gryada), другий фактор — ОТР (ТОТР/НОТР або апаратний токен). Жодна функція системи не доступна без успішного проходження обох факторів.

ІА-2(1) — MFA для привілейованих облікових записів (мережевий доступ). Адміністративні облікові записи додатково вимагають третій фактор — підтвердження через push-сповіщення на зареєстрований пристрій. Вхід зі "спільного" пристрою технічно заблокований.

ІА-2(2) — MFA для непривілейованих облікових записів. Стандартні користувачі автентифікуються мінімум двома факторами. Перший — сертифікат на смарт-карті (PKCS#15, алгоритм ДСТУ 4145-2002), другий — ПІН до смарт-карти.

ІА-5 — Управління автентифікаторами. `synrc/ca` є авторизованим джерелом криптографічних автентифікаторів (сертифікатів). Управління включає: реєстрацію (Certificate Enrollment via EST), оновлення (ACME/СМР), відкликання (OCSP/CRL) та архівування (Long-Term Validation, LTV). Усі автентифікатори прив'язані до апаратного носія (е-Токен, Грядда-301).

ІА-5(1) — Автентифікатори на основі пароля. Для сервісних облікових записів, де паролі все ж застосовуються, `ias` примусово застосовує мінімальну складність та зберігає паролі у форматі Argon2id (переможець РНС, стійкий до GPU-атак). Паролі ніколи не передаються у відкритому вигляді.

ІА-8 — Ідентифікація та автентифікація неорганізаційних користувачів. Для зовнішніх систем (наприклад, ЄДР, Дія) `ias` підтримує федерацію ідентичностей через SAML 2.0 та OIDC, де зовнішній IdP верифікує особу, а `ias` видає локальний токен з обмеженими правами на основі атрибутів, отриманих від зовнішнього провайдера.

6.8 Клас ІР: Реагування на інциденти

6.8.1 `erpuno/itsm`: ІР-1, ІР-4, ІР-5, ІР-6, ІР-8

ІР-1 — Політика та процедури реагування. Процеси реагування на інциденти формалізовані як BPMN-процеси в `synrc/bpmn` та виконуються через `erpuno/itsm`. Кожен тип інциденту (зі своїм кодом MITRE ATT&CK)

має призначений BPMN-шаблон із чіткими етапами: виявлення, класифікація, ескалація, усунення, пост-аналіз.

IR-4 — Обробка інцидентів. *itsm* автоматично отримує інциденти від Wazuh (via webhook) та *ias* (при виявленні аномалій AC-2(12)). Кожен інцидент отримує унікальний INC-ідентифікатор, прив'язаний до CMDB-запису компоненту, якого стосується.

IR-5 — Відстеження інцидентів. Повний аудит-трейл кожного інциденту (всі дії, коментарі, зміни статусу) зберігається в *kvs* та доступний для запиту. Тривалість зберігання — не менше 3 років.

IR-6 — Звітність про інциденти. *itsm* автоматично генерує щомісячні звіти про інциденти у форматі PDF (з використанням *synrc/ca* LaTeX-генератора) та надсилає їх CISO та відповідному регулятору (ДССЗІ).

6.9 Клас МА: Технічне обслуговування

6.9.1 *erpuno/itsm*: МА-2, МА-4, МА-5

МА-2 — Контрольоване обслуговування. Будь-яка планова технічна робота (обслуговування сервера, мережевого обладнання, HSM) оформлюється як Change Request (CR) в *itsm*. CR має обов'язкові поля: *maintainer_id*, *authorization_certificate* (X.509 підпис від авторизованого інженера), *maintenance_window*, *rollback_plan*.

МА-4 — Дистанційне обслуговування. Весь дистанційний доступ для обслуговування (SSH, RDP) маршрутизується через виділений Jump-сервер у Management VLAN. Доступ до Jump-сервера можливий лише з фіксованих IP через VPN-тунель *synrc/vpn* з обов'язковим MFA.

МА-5 — Персонал з обслуговування. Перелік авторизованого персоналу з обслуговування ведеться у CMDB (*roles.ex*) та верифікується *ias* перед наданням доступу. Несертифікований персонал технічно не може отримати доступ до систем.

6.10 Клас МР: Захист носіїв інформації

6.10.1 *synrc/kvs*: МР-2, МР-4, МР-5, МР-6, МР-7

МР-2, МР-4 — Доступ та зберігання носіїв. *kvs* є основним сховищем для усіх критичних даних ERP/1. Дані шифруються на рівні записів алгоритмами ДСТУ (Kalyna AES-256 GCM) ключами, що зберігаються в HSM ІІТ Gryada. Фізичний доступ до серверів з *kvs* обмежений Policy Engine та засобами PE-контролів.

МР-5 — Транспортування носіїв. Резервні копії на стрічку (HPE MSL3040) шифруються перед записом. Фізичні стрічки зберігаються у сейфі з подвійним контролем. Процедура виносу стрічки за периметр потребує авторизованого CR в *itsm*.

МР-6 — Знищення носіїв. Процедура знищення (DoD 5220.22-M або фізичне знищення для SSD/флеш) задокументована у *itsm* та реєструється у CMDB як факт деінвентаризації компоненту.

MP-7 — Використання носіїв. Використання знімних носіїв (USB) технічно заблоковано на рівні ОС (udev rules, Group Policy) для всіх робочих станцій, крім спеціально авторизованих технічних АРМ з дозволом CISO.

6.11 Клас SC: Захист систем та комунікацій

6.11.1 synrc/vpn: SC-7, SC-8, SC-10, SC-12, SC-28

SC-7 — Захист периметра. synrc/vpn реалізує строгий мережевий периметр на основі IPsec IKEv2 з автентифікацією через сертифікати X.509. Всі зовнішні підключення (між майданчиками, з віддаленими користувачами) проходять через VPN-тунелі. Cisco Firepower 4145 NGFW (задокументований у CMDB) фільтрує трафік на периметрі.

SC-7(3) — Точки доступу. Кількість зовнішніх мережевих підключень мінімізована та строго задокументована у net.ex CMDB. Кожна нова точка доступу потребує окремого CR та затвердження CISO.

SC-8 — Цілісність та конфіденційність передачі. Весь трафік між компонентами ERP/1 захищений mTLS 1.3 з обов’язковими ДСТУ-сумісними шифронаборами. Незашифрований трафік технічно неможливий — ias відхиляє запити без валідного TLS-сертифіката.

SC-12 — Встановлення та управління криптографічними ключами. synrc/ca є авторизованим ключовим центром. Кореневі ключі зберігаються виключно в HSM (Грядя-301) і ніколи не покидають апаратного модуля. Ротація ключів виконується за регламентом Церемонії Ключа з Dual Control.

SC-28 — Захист даних у стані спокою. PostgreSQL та Oracle використовують TDE (Transparent Data Encryption) з ключами від HSM. kvs виконує додаткове шифрування на рівні записів.

6.12 Клас SI: Цілісність системи та інформації

6.12.1 synrc/chat: SI-3, SI-4, SI-7, SI-10

SI-3 — Захист від шкідливого коду. Всі вузли кластера захищені Wazuh HIDS з актуальними сигнатурами. На рівні CI/CD-пайплайну виконується автоматичне сканування залежностей (SBOM, OWASP Dependency Check) при кожному коміті.

SI-4 — Моніторинг системи. Комбінація Wazuh (події безпеки) та Zabbix (метрики продуктивності) забезпечує 24/7 моніторинг всіх компонентів. Корелятор подій Wazuh детектує паттерни атак (MITRE ATT&CK) та автоматично ескалує їх до itsm.

SI-7 — Цілісність програмного забезпечення та інформації. Всі релізи ERP/1 підписуються цифровим підписом ДСТУ 4145-2002 від synrc/ca та публікуються разом з підписами. Контрольні суми (ДСТУ 7564-2014 Кирупа-512) перевіряються перед встановленням кожного оновлення.

SI-10 — Перевірка вхідних даних. synrc/chat та всі веб-компоненти ERP/1 (через synrc/ws) застосовують строгую схемну валідацію (JSON Schema

/ XSD) вхідних даних на рівні API Gateway перед передачею до бізнес-логіки.

6.13 Клас SR: Ризики ланцюга постачання

6.13.1 `synrc/chat` + `synrc/ca`: SR-3, SR-4, SR-5, SR-11

SR-3 — Заходи безпеки ланцюга постачання. ERP/1 використовує виключно компоненти з відкритим кодом (Erlang/OTP, Elixir), вихідний код яких верифікується перед включенням. SBOM (Software Bill of Materials) генерується автоматично при кожному збірці.

SR-4 — Провенанс. Всі компоненти мають криптографічно верифіковане походження. Підписи релізів перевіряються через `synrc/ca`-кореневий ЦСК. Незадокументований або непідписаний компонент не може бути встановлений у виробниче середовище.

SR-11 — Автентичність компоненту. Апаратні компоненти (HSM, комутатори, сервери) верифікуються через Serial Number та інвентаризаційний запис CMDDB. Постачальники (5HT Technology, ІІТ, Cisco) мають підписані угоди про безпеку ланцюга постачання.

6.14 Блоки PL, PS, RA, SA, PM, PT

6.14.1 `synrc/ca` CMDDB: PL-2, RA-2, RA-3, SA-5

PL-2 — Системний план безпеки. Цей самий PDF-звіт, що генерується програмно з CMDDB та LaTeX-шаблонів, є системним планом безпеки ERP/1. Він оновлюється автоматично при кожній зміні архітектури (що фіксується у Git).

RA-2 — Категоризація безпеки. Категоризація даних ERP/1 (Public, PII, Internal, Confidential) реалізована у `data.ex` CMDDB та автоматично прив'язується до вимог щодо криптографічного захисту та контролів доступу.

RA-3 — Оцінка ризику. Реєстр ризиків `risk.ex` CMDDB містить більше 40 задокументованих загроз (RISK-OS-01 ... RISK-DAT-02), прив'язаних до конкретних сімейств контролів NIST, що автоматично включаються до аналізу відповідності.

SA-5 — Системна документація. Вся архітектурна та безпекова документація ERP/1 генерується автоматично з вихідного коду (Documentation as Code). Це усуває феномен "documentation drift" та гарантує, що аудитори завжди оцінюють актуальний стан системи.

PM-2, PM-5, PM-6 — Програма безпеки, інвентаризація та метрики. Програма безпеки ERP/1 матеріалізована у CMDDB `synrc/ca`: ролі (PM-2), інвентаризація (PM-5), та ключові показники ефективності заходів (PM-6) є безпосередньо запитуваними через CMDDB API.

PT-2, PT-4 — Повноваження та згода на обробку ПД. Обробка персональних даних (реєстр підписників ЦСК) здійснюється виключно в

рамках цілей, задекларованих у CPS (Certificate Practice Statement). Згода суб'єкта ПД фіксується у *kvs* з криптографічним підписом.

7 Codebase Overview for Copyright Registration

The entire Configuration Management Database (CMDB), Continuous Accountability System, and PKI Certificate Authority components discussed in this document are implemented as a cohesive software suite. This software suite forms the basis for the formal registration of the copyright work.

The core architectural blocks of the codebase include:

- **SYS-SYNRC-CA:** The central Certificate Authority and HSM backend responsible for issuing X.509 certificates, OCSP, CRLs, and managing the entire PKI lifecycle via ACME and EST protocols.
- **CMDB Profiles:** The declarative Elixir modules defining the precise state of hardware (`hw.ex`), network topology (`net.ex`), and system applications (`sys.ex`).
- **Policy and Risk Engines:** Modules responsible for automated data categorization (`data.ex`), dynamic risk taxonomies (`risk.ex`), and strict role-based/attribute-based access controls (`roles.ex`, `abac.ex`).

The software is continuously developed, documented, and published at the following official resources:

- **Source Code Repository:** <https://github.com/synrc/ca>
- **Official Product Portal:** <https://erp.uno/ca/>
- **Developer Documentation:** <https://ca.n2o.dev>

8 Conclusion

By treating the Information Security Management System (ISMS) and the KSZI documentation as "Infrastructure as Code" (IaC) via Elixir maps, ERPUNO LLC achieves a continuous, verifiable, and strictly compliant security posture. This approach significantly reduces the friction typically associated with DSSZZI and NIST audits by ensuring that the actual state of the system is always perfectly synchronized with its certified documentation.

References

- [1] National Institute of Standards and Technology. *Security and Privacy Controls for Information Systems and Organizations*. NIST Special Publication 800-53, Revision 5.
- [2] Державна служба спеціального зв'язку та захисту інформації України. *НД ТЗІ 3.7-003-2023. Порядок проведення державної експертизи в сфері технічного захисту інформації*.
- [3] Державна служба спеціального зв'язку та захисту інформації України. *НД ТЗІ 2.5-004-99. Критерії оцінки захищеності інформації в комп'ютерних системах від несанкціонованого доступу*.
- [4] International Organization for Standardization. *ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements*.